COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Cryptographic Attacks

Mestre CyberSec · **Aula 2.4 — Cryptographic Attacks** (9:31) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Downgrade attack: convence as partes a usar protocolo FRACA (SSL strip: HTTPS→HTTP); hash collision (2 textos, mesmo hash — MD5 morreu por collision); brute force da chave. Defesa: HSTS (browser NUNCA aceita downgrade pra HTTP), patch crypto, algoritmo atual (TLS 1.3).

💡 Highlights que a prova CompTIA cobra

- Downgrade: convence pra usar versão FRACA (SSL stripping)
- HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip
- Collision MD5/SHA-1: dois textos, mesmo hash — abandonados

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'forces a connection to a weaker protocol' = downgrade attack
- 'prevents downgrade to HTTP' = HSTS

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Cryptographic Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque de Downgrade (N/A)

Um ataque que força as partes a negociar um protocolo ou conjunto de cifras mais antigo e fraco em vez da opção mais forte suportada.

⚠️ ***Armadilha CompTIA:*** *Se a questão disser 'forces a connection to a weaker protocol', marque downgrade attack; não confunda com SSL stripping, que é uma forma específica de downgrade de HTTPS para HTTP.*

• SSL Stripping (Remoção de SSL) (N/A)

Um ataque de downgrade em que o atacante intercepta tráfego HTTPS e o repassa à vítima como HTTP, removendo a criptografia TLS.

⚠️ ***Armadilha CompTIA:*** *Associe SSL stripping a downgrade HTTPS→HTTP; HSTS é a mitigação porque o navegador se lembra de exigir HTTPS.*

• Segurança Estrita de Transporte HTTP (HSTS)

Uma política de segurança web que instrui navegadores a se conectarem ao site somente via HTTPS e nunca permitirem downgrade para HTTP.

⚠️ ***Armadilha CompTIA:*** *Se a questão pergunta o que impede downgrade para HTTP/SSL strip, a resposta é HSTS.*

• Colisão de Hash (N/A)

Situação em que duas entradas diferentes produzem o mesmo valor de hash, quebrando garantias de integridade e assinatura digital.

⚠️ ***Armadilha CompTIA:*** *Duas mensagens diferentes com o mesmo hash = colisão. MD5 e SHA-1 são abandonados justamente por colisões.*

• MD5 (Message Digest 5)

Algoritmo de hash de 128 bits obsoleto e criptograficamente quebrado devido a ataques práticos de colisão.

⚠️ ***Armadilha CompTIA:*** *Se a questão citar MD5, geralmente é para indicar hash fraco/colisão; prefira SHA-256/SHA-3.*

• SHA-1 (Algoritmo de Hash Seguro 1)

Algoritmo de hash de 160 bits obsoleto e vulnerável a ataques de colisão, não mais aprovado para uso seguro.

⚠️ ***Armadilha CompTIA:*** *SHA-1 também sofreu colisão; CompTIA espera que você saiba que MD5 e SHA-1 não devem ser usados para integridade/assinaturas.*

• Ataque de Força Bruta (N/A)

Ataque que tenta sistematicamente todas as chaves, senhas ou combinações possíveis até encontrar a correta.

⚠️ ***Armadilha CompTIA:*** *Se a questão mencionar tentar todas as combinações/chaves, é brute force; defenda com chaves longas, algoritmos fortes e limitação de tentativas.*

• Segurança da Camada de Transporte 1.3 (TLS 1.3)

Versão atual do TLS que remove algoritmos legados fracos e inclui proteção contra downgrade para negociação segura.

⚠️ ***Armadilha CompTIA:*** *TLS 1.3 é a resposta atual para evitar downgrade; SSL e TLS antigos (1.0/1.1) são fracos/obsoletos.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Ataque do Aniversário e Colisão de Hash (Birthday Attack & Hash Collisions)

🏠 **Analogia Intuitiva:** Em uma sala com apenas 23 pessoas, a probabilidade matemática de que pelo menos duas façam aniversário no mesmíssimo dia do ano já é superior a 50%. O segredo é que você não está procurando alguém que faça aniversário no SEU dia específico; você só quer achar QUALQUER par de pessoas que coincida. Em um ataque de aniversário, o fraudador cria dois documentos totalmente diferentes (um contrato inocente e outro transferindo o patrimônio da vítima para ele) e faz pequenas alterações invisíveis nos textos (adicionando espaços ou pontuação) até que ambos gerem exatamente o mesmo código de hash. Ele faz a vítima assinar digitalmente o documento bom, mas cola a assinatura válida no documento fraudulento.

🔍 **Causa Raiz / Por que foi criado:** O paradoxo do aniversário reduz drasticamente o número de tentativas necessárias para encontrar duas entradas que produzam a mesma saída de hash (de 2^n para 2^(n/2)). Algoritmos de hash antigos com saídas curtas ou fraquezas matemáticas (como MD5 de 128 bits e SHA-1 de 160 bits) tornam viável gerar colisões de hash na prática.

🛡️ **Visão do Auditor de GRC:** Proibir expressamente em políticas de conformidade (PCI-DSS, ISO 27001, FIPS 140-3) o uso de algoritmos obsoletos como MD5 e SHA-1; homologar apenas funções hash modernas e resistentes a colisões como SHA-256 (família SHA-2) e SHA-3.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker generates two different inputs that produce the exact same cryptographic hash value' -> Hash Collision / Birthday Attack. Pegadinha: A banca quase sempre cita MD5 ou SHA-1 como o exemplo de algoritmo suscetível.

📌 Downgrade Attack e SSL Stripping

🏠 **Analogia Intuitiva:** O Downgrade Attack é como você chegar na embaixada falando inglês moderno fluente com um sistema seguro e o guarda corrupto no portão falar: 'O tradutor moderno está fora do ar, você é obrigado a falar no dialeto antigo e fraco do século XV', permitindo que qualquer pessoa escutando no corredor decifre sua mensagem. O SSL Stripping é o carteiro interceptar a carta que você mandou lacrada em um cofre com cadeado (HTTPS), arrancar a carta de dentro do cofre, colocá-la em um envelope de papel transparente comum (HTTP) e entregar na agência do banco, permitindo que qualquer pessoa no caminho leia suas senhas em texto claro.

🔍 **Causa Raiz / Por que foi criado:** Para manter compatibilidade com navegadores ou sistemas legados antigos, servidores aceitavam negociar versões criptográficas antiquadas (como SSL 3.0, TLS 1.0 ou cifras export). No SSL stripping, um atacante on-path intercepta a requisição HTTP inicial e impede o redirecionamento automático para HTTPS.

🛡️ **Visão do Auditor de GRC:** Desativar permanentemente protocolos obsoletos no servidor web (bloquear SSLv2, SSLv3, TLS 1.0, TLS 1.1) permitindo apenas TLS 1.2 e TLS 1.3; e configurar o cabeçalho HSTS (HTTP Strict Transport Security) com a diretiva `includeSubDomains; preload` para forçar os navegadores a nunca aceitarem conexões HTTP puras.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker forces a client and server to abandon modern encryption and communicate using an older, insecure protocol' -> Downgrade Attack. Trigger: 'attacker intercepts web traffic and strips HTTPS encryption, downgrading session to plain HTTP' -> SSL Stripping (Mitigação: HSTS).

📌 Replay Attacks e Proteções com Nonce & Timestamps

🏠 **Analogia Intuitiva:** Um ataque de repetição (Replay) é como você gravar em fita cassete o som do seu chefe destrancando o cofre eletrônico por comando de voz dizendo: 'Abre cofre, senha Alfa'. À noite, quando não há ninguém, o ladrão entra na sala vazia, aperta o 'play' na fita cassete e o cofre abre, mesmo sem o ladrão saber como a senha foi criada. O Nonce (número de uso único) é o cofre responder antes de abrir: 'Diga a senha seguida do número aleatório único que acabou de aparecer no visor agora: 7392'. Como o número 7392 só vale uma única vez e expira em 5 segundos (timestamp), a gravação de ontem na fita cassete se torna inútil e o cofre rejeita a tentativa.

🔍 **Causa Raiz / Por que foi criado:** Protocolos de autenticação que não incluem dados aleatórios efêmeros e carimbos de tempo transmitem credenciais ou hashes estáticos (ex: NTLM). O invasor captura os pacotes na rede e os retransmite sem precisar decifrar a senha original.

🛡️ **Visão do Auditor de GRC:** Auditar a desativação de protocolos legados suscetíveis a replay (como NTLM e LM) em favor de Kerberos (que exige sincronização de relógio via NTP e tíquetes com timestamps); e exigir uso de tokens criptográficos descartáveis com Nonce em APIs e transações bancárias.

⚠️ **Como cai na Prova CompTIA:** Trigger: 'attacker captures legitimate authentication packets on the wire and retransmits them later to gain unauthorized access' -> Replay Attack. Mitigações essenciais: Nonce (Number used once) e Timestamps.

📌 Texto Claro Conhecido vs. Somente Texto Cifrado (Known Plaintext vs. Ciphertext-Only)

🏠 **Analogia Intuitiva:** Somente Texto Cifrado (Ciphertext-Only) é o detetive encontrar um pergaminho com símbolos alienígenas indecifráveis em um cofre, sem ter a menor pista de que idioma ou assunto está escrito ali dentro. Texto Claro Conhecido (Known Plaintext) é o espião interceptar o mesmo pergaminho cifrado, mas já saber com certeza absoluta que a primeira frase do documento sempre começa com 'Ao Presidente da República:' porque todas as cartas oficiais daquele órgão começam com esse cabeçalho idêntico. Ao comparar a frase conhecida com os símbolos cifrados correspondentes, o espião deduz o segredo da cifra.

🔍 **Causa Raiz / Por que foi criado:** Protocolos ou arquivos que utilizam cifras fracas ou modos de operação inadequados (como AES em modo ECB - Electronic Codebook) cifram blocos de dados idênticos sempre no mesmo texto cifrado correspondente. Conhecer trechos fixos de cabeçalhos de arquivos permite deduzir a chave criptográfica.

🛡️ **Visão do Auditor de GRC:** Proibir o uso de modos de operação determinísticos (proibir ECB) em políticas de desenvolvimento seguro (OWASP ASVS); exigir cifras em modos autenticados e probabilísticos (como AES-GCM ou CBC com Vetor de Inicialização / IV criptograficamente aleatório e imprevisível).

⚠️ **Como cai na Prova CompTIA:** Trigger: 'analyst has access to both an encrypted message and its corresponding decrypted original plaintext for portions of the transmission' -> Known Plaintext Attack. Se o atacante possuir estritamente apenas a mensagem criptografada sem nenhum texto claro: Ciphertext-Only Attack.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Atacante encontra duas mensagens de texto totalmente diferentes que geram exatamente o mesmo valor de hash criptográfico	**Colisão de Hash / Ataque do Aniversário (Birthday Attack)**
Invasor força a comunicação a abandonar cifras seguras e negociar uma versão de protocolo antiga e cheia de falhas	**Downgrade Attack**
Cabeçalho web de segurança que instrui o navegador a comunicar-se exclusivamente através de conexões HTTPS criptografadas	**HSTS (HTTP Strict Transport Security)**
Invasor captura pacotes válidos de autenticação na rede e os reenvia mais tarde para se passar pelo usuário sem decifrar a senha	**Ataque de Repetição (Replay Attack)**
Valor numérico aleatório de uso único gerado a cada autenticação para garantir que requisições repetidas sejam rejeitadas	**Nonce (Number Used Once)**
Criptoanalista possui trechos do texto original em claro e seus respectivos blocos cifrados para deduzir a chave de cifragem	**Ataque de Texto Claro Conhecido (Known Plaintext Attack)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um usuário se conecta a uma rede Wi-Fi de cafeteria e digita http://portal.example.com. Um atacante intercepta a solicitação inicial, mantém o navegador comunicando-se via HTTP e faz proxy silenciosamente das solicitações para o site HTTPS real enquanto registra credenciais. Qual ataque está sendo descrito?

A) Ataque de SSL stripping/downgrade

B) Ataque de colisão de hash

C) Recuperação de chave por força bruta

D) Bypass de certificate pinning

QUESTÃO 2 · CENÁRIO DE EXAME

Após um incidente de SSL stripping em redes públicas, uma empresa quer que os navegadores nunca façam downgrade silencioso de HTTPS para HTTP para seu domínio e todos os subdomínios. Qual implantação o engenheiro de segurança deve implementar?

A) DNSSEC com validação NSEC3

B) Política HSTS com includeSubDomains e preload

C) Assinatura de código SHA-256 para todos os aplicativos

D) TLS 1.3 com perfect forward secrecy apenas

QUESTÃO 3 · CENÁRIO DE EXAME

Um pesquisador de segurança envia dois arquivos PDF diferentes que produzem o mesmo digest MD5. Um insider malicioso planeja substituir um contrato benigno por um fraudulento mantendo o checksum MD5 publicado inalterado. Qual ataque criptográfico isso ilustra?

A) Ataque de downgrade

B) Recuperação de chave por força bruta

C) Ataque de colisão de hash

D) Ataque de replay

QUESTÃO 4 · CENÁRIO DE EXAME

Um aplicativo interno legado assina atualizações de software com SHA-1. O fornecedor alerta que um atacante poderia criar uma atualização maliciosa com o mesmo valor SHA-1 de uma atualização legítima. Qual risco o fornecedor está descrevendo?

A) Falha de resistência a colisões

B) Downgrade de suíte de cifras

C) Esgotamento de chave

D) Bypass de HSTS

QUESTÃO 5 · CENÁRIO DE EXAME

Um atacante captura um arquivo criptografado protegido com uma chave DES de 56 bits. O atacante tenta sistematicamente todas as chaves possíveis até que o arquivo seja aberto. Que tipo de ataque é este?

A) Colisão de hash

B) SSL stripping

C) Ataque de downgrade

D) Ataque de força bruta

QUESTÃO 6 · CENÁRIO DE EXAME

Durante um handshake TLS, um man-in-the-middle modifica o client hello e o server hello para que a conexão use TLS 1.0 em vez de TLS 1.3. Qual ataque ocorreu?

A) Ataque de colisão de hash

B) Ataque de downgrade

C) Busca de chave por força bruta

D) Cross-site request forgery

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa habilita HSTS para app.example.com, mas não define includeSubDomains. Qual risco residual permanece?

A) Certificados MD5 no domínio principal tornam-se propensos a colisões.

B) Sessões TLS 1.3 farão fallback automaticamente para SHA-1.

C) Um subdomínio como login.example.com ainda pode sofrer downgrade na primeira visita de um usuário.

D) Ataques de força bruta contra AES-256 tornam-se viáveis.

QUESTÃO 8 · CENÁRIO DE EXAME

Um servidor web suporta TLS 1.0, TLS 1.1, TLS 1.2 e TLS 1.3. Os administradores querem reduzir a chance de clientes negociarem protocolos obsoletos durante um handshake man-in-the-middle. Qual mudança no servidor é mais apropriada?

A) Substituir a assinatura de certificado SHA-256 do servidor por MD5.

B) Habilitar HSTS apenas para HTTP na porta 80.

C) Aumentar o tamanho da chave RSA de 2048 para 3072 bits apenas.

D) Desabilitar TLS 1.0 e TLS 1.1 e exigir TLS 1.2 ou TLS 1.3.

QUESTÃO 9 · CENÁRIO DE EXAME

Um sistema de build de software verifica binários de release comparando hashes SHA-1. A liderança de segurança quer proteger contra um adversário que crie um binário malicioso com o mesmo hash do binário aprovado. Qual ação deve ser tomada primeiro?

A) Migrar as verificações de integridade de release para SHA-256 ou SHA-3.

B) Aplicar HSTS preload no servidor de build.

C) Reduzir as suítes de cifras TLS para 3DES.

D) Armazenar os hashes SHA-1 em um registro DNS TXT público.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização usa um dispositivo embarcado que criptografa telemetria com uma chave simétrica de 64 bits. Um testador de penetração recupera a chave tentando todos os valores possíveis offline. Qual remediação reduz mais diretamente esse risco de força bruta?

A) Habilitar HSTS na interface web de gerenciamento do dispositivo.

B) Substituir o algoritmo/tamanho da chave por AES-256.

C) Trocar a integridade de mensagem de SHA-256 para MD5.

D) Exigir que usuários alterem senhas a cada 30 dias.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Ataque de SSL stripping/downgrade

SSL stripping é um ataque de downgrade no qual o atacante impede o navegador de atualizar para HTTPS e retransmite o tráfego para o site real. Colisões de hash envolvem duas entradas com o mesmo digest, força bruta adivinha chaves, e bypass de certificate pinning é uma preocupação diferente de interceptação TLS. HSTS é a principal defesa contra SSL stripping.

Questão 2: Alternativa B — Política HSTS com includeSubDomains e preload

HSTS instrui o navegador a sempre usar HTTPS para um host e a recusar tentativas do usuário ou de atacantes de fazer downgrade para HTTP. As diretivas includeSubDomains e preload estendem essa proteção a subdomínios e ajudam antes da primeira visita. DNSSEC protege a integridade do DNS, assinatura de código protege software, e TLS 1.3 fortalece o handshake, mas por si só não impede que uma URL HTTP inicial seja interceptada.

Questão 3: Alternativa C — Ataque de colisão de hash

Uma colisão de hash ocorre quando duas entradas diferentes produzem o mesmo valor de hash. O MD5 não é mais considerado resistente a colisões, então um atacante pode substituir um arquivo fraudulento preservando o checksum. Ataques de downgrade e força bruta visam protocolos ou chaves, e um ataque de replay reutiliza dados válidos capturados.

Questão 4: Alternativa A — Falha de resistência a colisões

O SHA-1 tem fraquezas de colisão conhecidas, significando que um atacante pode gerar duas atualizações diferentes com o mesmo digest. Isso quebra a verificação de integridade baseada em SHA-1. Um downgrade de suíte de cifras visa a negociação de protocolo, esgotamento de chave não é o problema central, e HSTS está relacionado à prevenção de downgrade no transporte web.

Questão 5: Alternativa D — Ataque de força bruta

Tentar todas as chaves possíveis até encontrar a correta é um ataque de força bruta. O espaço de chave DES de 56 bits é pequeno o suficiente para ser esgotado com hardware moderno. Colisões de hash visam digests, SSL stripping faz downgrade de HTTP, e um ataque de downgrade enfraquece a negociação de protocolo.

Questão 6: Alternativa B — Ataque de downgrade

Um ataque de downgrade força duas partes a negociar um protocolo ou cifra mais antigo e fraco do que normalmente suportariam. Aqui o MITM manipula o handshake para selecionar TLS 1.0 em vez de TLS 1.3. Colisões de hash visam digests de integridade, força bruta adivinha chaves, e CSRF é um ataque de aplicação web.

Questão 7: Alternativa C — Um subdomínio como login.example.com ainda pode sofrer downgrade na primeira visita de um usuário.

Sem includeSubDomains, a política HSTS se aplica apenas a app.example.com e não aos seus subdomínios. Um atacante ainda pode fazer stripping de HTTPS em um subdomínio desprotegido, especialmente antes que o HSTS seja conhecido. Risco de certificado MD5, fallback de TLS 1.3 para SHA-1, e força bruta contra AES-256 não são consequências precisas dessa configuração de HSTS.

Questão 8: Alternativa D — Desabilitar TLS 1.0 e TLS 1.1 e exigir TLS 1.2 ou TLS 1.3.

Remover TLS 1.0 e TLS 1.1 dos protocolos suportados pelo servidor impede que clientes e atacantes negociem essas versões obsoletas. Exigir TLS 1.2 ou TLS 1.3, idealmente apenas TLS 1.3, fortalece o handshake. MD5 enfraquece assinaturas, HSTS na porta 80 está mal configurado, e uma chave RSA maior não impede downgrade de protocolo.

Questão 9: Alternativa A — Migrar as verificações de integridade de release para SHA-256 ou SHA-3.

O SHA-1 é considerado fraco para resistência a colisões, então a verificação de integridade deve migrar para um hash moderno como SHA-256 ou SHA-3. HSTS e registros DNS TXT não corrigem o risco de colisão de hash, e usar 3DES enfraquece a segurança do transporte.

Questão 10: Alternativa B — Substituir o algoritmo/tamanho da chave por AES-256.

A resistência à força bruta depende do espaço de chaves; mudar de uma chave de 64 bits para AES-256 aumenta muito o número de chaves possíveis e torna a busca exaustiva inviável. HSTS protege o transporte web, MD5 enfraquece a integridade, e expiração de senha não resolve a chave simétrica de telemetria.